

# Plan personal de estudio de 16 semanas

## Ritmo y reglas

- Cinco sesiones por semana, 90-120 minutos cada una; objetivo: 8-10 horas.
- Días 1-3: adquisición y ejercicios. Día 4: adaptación/transferencia. Día 5: laboratorio y mini evaluación.
- Usa la plantilla de sesión, el sistema de pistas y el registro de autonomía.
- No avances por lectura completada. Avanza cuando puedas explicar el flujo, diseñar un control y resolver una variación.
- Los laboratorios deben ser propios, locales, CTF o entornos expresamente autorizados.

## Vista general

| Semana | Foco único o familia estrecha           | Evidencia final                                        |
|--------|-----------------------------------------|--------------------------------------------------------|
| 1      | HTTP, sesiones y Burp                   | Matriz de peticiones y análisis de sesión              |
| 2      | Redes, DNS, URLs y normalización        | Trazado nombre → IP → conexión → parser                |
| 3      | Shell, procesos, argumentos y argv      | Experimento que distingue shell/ejecución directa      |
| 4      | Source → transformación → parser → sink | Mapa de flujo y checkpoint 1                           |
| 5      | Construcción y adaptación de payloads   | Tres payloads justificados por componentes             |
| 6      | SQLi                                    | Consulta reconstruida y oráculo controlado             |
| 7      | Traversal y LFI                         | Ruta normalizada y separación lectura/include          |
| 8      | SSRF                                    | Callback atribuido y política de destino; checkpoint 2 |
| 9      | Command vs argument injection           | Clasificación experimental de ejecución                |
| 10     | File upload                             | Pipeline de almacenamiento e interpretación            |
| 11     | Autenticación, sesiones y MFA           | Matriz identidad/estado/objeto                         |
| 12     | Linux: enumeración, sudo y SUID         | Relación permiso-identidad-capacidad; checkpoint 3     |
| 13     | Linux: cron y PATH                      | Consumidor privilegiado y entorno efectivo             |
| 14     | Windows privilege escalation            | Matriz servicio/ACL/identidad/precondición             |
| 15     | Active Directory                        | Grafo de identidades, tickets y permisos               |
| 16     | Redes, análisis y pivoting              | Ruta diagnosticada y checkpoint final                  |

## Semana 1 — HTTP, sesiones y Burp

La ejecución diaria completa está en [semana\\_01.md](#).

- Lectura en orden: [HTTP y sesiones](#) → [chuleta HTTP y Burp](#) → secciones Modelo mental, Prueba mínima y Caso guiado de [autenticación y sesiones](#).
- Dominar: anatomía de petición/respuesta, ubicación de entradas, cookie frente a estado server-side, autenticación frente a autorización, baseline y cambio de una variable.
- Ejercicios: E01, E03 y E17 del [cuaderno](#).
- Laboratorio tipo: aplicación HTTP local con login, dos usuarios y proxy de interceptación.

- Objetivo práctico: capturar, enviar a Repeater y construir una matriz sesión/objeto con controles.
- Mini evaluación: reconstruir una petición sin apuntes y explicar tres respuestas distintas.
- Completada si: 4/5 sesiones, E01/E03/E17 razonados, matriz con baseline y control, mini evaluación  $\geq 70\%$  y registro de ayuda.

## Semana 2 — Redes, DNS, URLs y parsing

- Lectura en orden: Redes, DNS, puertos y URLs → Encoding, normalización y parsers → URL y autoridad, Resolución y ejemplos aplicables de SSRF, sin estudiar aún sus casos.
- Distribución: D1 URL/autoridad; D2 DNS/conexión; D3 decodificación/normalización; D4 parsing diferencial; D5 laboratorio y evaluación.
- Dominar: esquema, autoridad, host efectivo, fragmento, resolución, vhost, orden de decode/validación y diferencia puerto-servicio.
- Ejercicios: E04, E11 y una repetición D7 de E01 con otra petición.
- Laboratorio tipo: dos vhosts locales, DNS/hosts controlado y endpoint que registra URL antes/después de decodificar.
- Objetivo práctico: dibujar el recorrido texto URL → parser → DNS → IP → socket → Host y localizar una validación en orden incorrecto.
- Mini evaluación: cinco URLs ambiguas; predecir qué consume cliente, DNS y servidor.
- Completada si: 8/10 predicciones justificadas, laboratorio con dos hipótesis rivales y nivel de autonomía registrado.

## Semana 3 — Shell, procesos, argumentos y argv

- Lectura en orden: Linux, procesos, permisos y shell completo → Caso 2 y Argumentos y opciones de construcción de payloads → chuleta command/argument.
- Distribución: D1 procesos/credenciales; D2 pipeline Bash; D3 quoting/operadores; D4 argv/option parsing; D5 experimento ciego.
- Dominar: shell expansion, quoting, splitting, globbing, execve, elementos de argv, opción frente a operando.
- Ejercicios: E06, E23 y E25.
- Laboratorio tipo: wrapper local instrumentado con modos shell=True, cadena con sh -c y lista argv.
- Objetivo práctico: predecir y observar por qué ; id se ejecuta, queda literal, da error o no produce señal.
- Mini evaluación: clasificar seis trazas de proceso sin ver el código.
- Completada si:  $\geq 5/6$  clasificaciones con experimento discriminatorio y E25 sin solucionario por encima de nivel D.

## Semana 4 — Flujo de datos y método experimental

- Lectura en orden: Bases de datos y flujo de datos → Metodología de laboratorio → Modelo mental de construcción de payloads.
- Distribución: D1 source/sink; D2 transformaciones/confianza; D3 hipótesis/certeza; D4 caso de demora y abandono; D5 checkpoint 1.
- Dominar: source → transformaciones → parser → sink, certeza, controles, hipótesis rivales y criterio de abandono.
- Ejercicios: E02, E12 y E21.
- Laboratorio tipo: API local con transformaciones visibles y dos causas posibles para el mismo error.
- Objetivo práctico: producir un mapa de flujo y un experimento que separe dos explicaciones.
- Mini evaluación: Checkpoint 1.
- Completada si: checkpoint  $\geq 20/28$ , ninguna dimensión en 0 y autonomía registrada.

## Semana 5 — Construcción y adaptación de payloads

- Lectura en orden: Construcción y adaptación de payloads: Método de construcción → Diagnóstico general → Árbol → cinco casos → Anatomía obligatoria.
- Distribución: D1 método/anatomía; D2 cierre y encoding; D3 canales de evidencia; D4 casos 1-3; D5 casos 4-5 y prueba.
- Dominar: sintaxis envolvente, payload mínimo, significado de componentes, control negativo, restricción y adaptación causal.
- Ejercicios: E22, E23 y reconstrucción escrita de dos casos sin mirar.
- Laboratorio tipo: tres mini sinks locales (consulta simulada, ruta y wrapper de proceso) con una restricción cada uno.
- Objetivo práctico: construir tres pruebas desde contexto vacío, no desde listas.
- Mini evaluación: recibir una sintaxis desconocida y entregar anatomía completa en 25 minutos.
- Completada si: tres anatomías con predicciones verificables; al menos dos resueltas en nivel A-C.

## Semana 6 — SQLi

- Lectura en orden: Bases de datos, Reconstruir la consulta → SQLi completo → chuleta SQLi solo al cierre.
- Distribución: D1 consulta/contexto; D2 oráculos; D3 anatomía/casos A-B; D4 transferencia/falso positivo; D5 laboratorio.
- Dominar: contexto numérico/textual, sufijo, par verdadero/falso, canal de evidencia y adaptación por motor solo tras identificarlo.
- Ejercicios: E05, E22 y E03 como falso positivo.
- Laboratorio tipo: aplicación SQL local con dos parámetros en contextos distintos y errores ocultos.
- Objetivo práctico: reconstruir consulta probable y confirmar sin extraer datos.
- Mini evaluación: adaptar un par booleano cuando la comilla inicial falla.
- Completada si: baseline + verdadero + falso reproducibles, consulta documentada y control de aplicación.

## Semana 7 — Traversal y LFI

- Lectura en orden: Orden de procesamiento de encoding y parsers → LFI completo → chuleta LFI al final.
- Distribución: D1 normalización; D2 traversal/lectura; D3 include/interpretación; D4 sufijos/wrappers/permisos; D5 laboratorio.
- Dominar: ruta base, ruta canónica, traversal frente a lectura/include, sufijo, permisos y falso positivo por error simulado.
- Ejercicios: E07, E11 y una variante propia de E07 con otra profundidad.
- Laboratorio tipo: selector de informes local con modo lectura y modo include diferenciados.
- Objetivo práctico: normalizar a mano, seleccionar marcador y demostrar qué sink existe.
- Mini evaluación: tres respuestas iguales con causas distintas; diseñar controles.
- Completada si: ruta final correcta, sink clasificado y ninguna afirmación de ejecución sin evidencia.

## Semana 8 — SSRF

- Lectura en orden: repaso redes y URLs → SSRF completo → chuleta SSRF solo para recuperación.
- Distribución: D1 cliente/servidor; D2 callback/localhost; D3 IP/DNS; D4 redirects/herramienta/protocolos; D5 checkpoint 2.
- Dominar: atribución de callback, destino efectivo, resolución, representación, revalidación de redirect y capacidades observadas del cliente.
- Ejercicios: E08, E21 y E26.

- Laboratorio tipo: fetcher local con listener, redirector y DNS/hosts controlado.
- Objetivo práctico: diferenciar petición client-side/server-side y localizar dónde se aplica el filtro.
- Mini evaluación: [Checkpoint 2](#).
- Completada si: checkpoint  $\geq 20/28$ , callback atribuido y política dibujada sin depender de payload final ajeno.

## Semana 9 — Command vs argument injection

- Lectura en orden: [Command injection](#) → [Argument injection](#), especialmente comparación → [chuleta conjunta](#).
- Distribución: D1 shell; D2 blind/controles; D3 splitting/opciones; D4 comparación/transferencia; D5 laboratorio ciego.
- Dominar: sh -c frente a ejecución directa, canales blind, splitting real, option injection y operandos adicionales.
- Ejercicios: E06, E23 y E25.
- Laboratorio tipo: cuatro endpoints clonados que usan shell, un argumento, splitting y opción.
- Objetivo práctico: identificar el modelo de ejecución con pruebas inocuas.
- Mini evaluación: clasificar cuatro endpoints y justificar el siguiente experimento.
- Completada si: 4/4 modelos identificados o descartados con controles; no se usa ; id como única evidencia.

## Semana 10 — File upload

- Lectura en orden: [File upload](#) completo → [chuleta file upload](#) al cierre.
- Distribución: D1 subida/validación; D2 almacenamiento; D3 recuperación/handler; D4 casos B-D; D5 matriz práctica.
- Dominar: upload → almacenamiento → recuperación → interpretación → ejecución; nombre, MIME, bytes, ruta, permisos y autorización.
- Ejercicios: E09 y E24.
- Laboratorio tipo: gestor local de adjuntos con renombrado, descarga y dos identidades.
- Objetivo práctico: cambiar una dimensión por prueba y localizar la capa decisora.
- Mini evaluación: evaluar cinco evidencias y declarar solo capacidades confirmadas.
- Completada si: matriz completa, hashes/cabeceras registrados y no se equipara subida con ejecución.

## Semana 11 — Autenticación, sesiones y MFA

- Lectura en orden: [Autenticación y sesiones](#) → [MFA/OTP](#) → Modelo mental de [API testing](#).
- Distribución: D1 sesión/estado; D2 autorización/binding; D3 expiración/revocación; D4 MFA/replay; D5 matriz práctica.
- Dominar: identidad, estado, objeto, binding, frescura, consumo, replay, expiración y revocación.
- Ejercicios: E13, E17 y una matriz propia de login → pre-MFA → MFA → logout.
- Laboratorio tipo: API local con dos usuarios, sesión pre/post MFA y recurso con propietario.
- Objetivo práctico: separar autenticación, transición y autorización cambiando una variable.
- Mini evaluación: encontrar la explicación correcta de cuatro 200/401/403 sin inferir por código únicamente.
- Completada si: matriz identidad-estado-objeto reproducible y logout/replay verificados con controles.

## Semana 12 — Linux: enumeración, sudo y SUID

- Lectura en orden: [Enumeración Linux](#) → [sudo](#) → [SUID](#).
- Distribución: D1 inventario/identidad; D2 consumidores privilegiados; D3 sudo; D4 SUID; D5 checkpoint 3.
- Dominar: hallazgo, relación de permisos, RunAs/RUID/EUID, argumentos, entorno, nosuid, no\_new\_privs, capacidad mínima.
- Ejercicios: E14, E18 y falso positivo SUID del módulo.

- Laboratorio tipo: VM Linux local con reglas sudo y binarios marcadores deliberadamente seguros.
- Objetivo práctico: pasar de listado a precondiciones y evidencia de identidad efectiva.
- Mini evaluación: [Checkpoint 3](#).
- Completada si: checkpoint  $\geq 20/28$  y dos hallazgos descartados correctamente además de uno confirmado.

## Semana 13 — Linux: cron y PATH

- Lectura en orden: [Cron](#) → [PATH hijacking](#) → Resumen de [capabilities](#).
- Distribución: D1 cron/entorno; D2 componentes escribibles; D3 PATH del consumidor; D4 transferencia timer/wrapper; D5 mini-room.
- Dominar: usuario efectivo, ciclo, shell, PATH, cwd, archivo consumido, ruta absoluta y permisos del directorio.
- Ejercicios: E20 y E27.
- Laboratorio tipo: VM con tarea periódica inocua, PATH explícito y directorios con ACL contrastadas.
- Objetivo práctico: demostrar o descartar control de un componente realmente consumido por root.
- Mini evaluación: resolver E27 con máximo nivel C y justificar dos falsos positivos.
- Completada si: marcador mínimo, restauración del entorno y cadena de precondiciones documentada.

## Semana 14 — Windows privilege escalation

- Lectura en orden: [Enumeración Windows](#) → [servicios](#) → [credenciales almacenadas](#) → [chuleta Windows](#) al final.
- Distribución: D1 identidad/sistema; D2 ACL de servicios/rutas; D3 cuentas/credenciales; D4 adaptación y falso positivo; D5 laboratorio.
- Dominar: servicio, cuenta, ruta, ACL, control de reinicio, privilegio de token y precondiciones.
- Ejercicios: E15 y una adaptación propia con ruta entrecomillada pero directorio escribible.
- Laboratorio tipo: VM Windows de práctica con servicios y ACL deliberadas.
- Objetivo práctico: transformar un hallazgo de servicio en matriz de condiciones, no en explotación automática.
- Mini evaluación: analizar tres configuraciones y elegir la única con cadena completa.
- Completada si: ACL y control de servicio verificados, identidad destino explicada y nivel de ayuda registrado.

## Semana 15 — Active Directory

- Lectura en orden: [Modelo AD](#) → [Kerberos](#) → [LDAP](#) → [BloodHound](#).
- Distribución: D1 identidades/objetos; D2 tickets/hora; D3 LDAP; D4 grafo/permisos; D5 caso integrado.
- Dominar: principal, ticket, servicio, SPN, directorio, relación de permiso, precondición y diferencia autenticación/autorización.
- Ejercicios: E16 y análisis de una ruta BloodHound ficticia con una precondición falsa.
- Laboratorio tipo: dominio aislado de entrenamiento o dataset/graph export sin explotación.
- Objetivo práctico: consultar identidad y relaciones, interpretar error y validar una arista.
- Mini evaluación: explicar una ruta de tres aristas y cómo descartar cada una.
- Completada si: ninguna arista se trata como impacto confirmado y el error temporal se separa de permisos.

## Semana 16 — Redes, análisis y pivoting

- Lectura en orden: [Metodología de reconocimiento](#) → [Análisis de paquetes](#) → [Segmentación y firewalls](#) → [Pivoting](#) → [diagnóstico](#).
- Distribución: D1 reconocimiento; D2 tráfico; D3 rutas/firewall; D4 túnel/diagnóstico; D5 checkpoint final.
- Dominar: servicio observado, flujo, interfaz, ruta, listener, alcance, túnel y prueba por salto.

- Ejercicios: E04, E19 y una repetición sorpresa D45 de un ejercicio débil anterior.
- Laboratorio tipo: dos redes virtuales aisladas con un host puente y captura autorizada.
- Objetivo práctico: demostrar conectividad por etapas y localizar dónde falla un túnel.
- Mini evaluación: Checkpoint 4.
- Completada si: checkpoint  $\geq 21/28$ , autonomía A-C en mini laboratorio o mejora de dos niveles respecto al checkpoint anterior.

## Política de repetición

| Momento | Acción                                      | Duración      | Qué registrar                        |
|---------|---------------------------------------------|---------------|--------------------------------------|
| Día 0   | Aprender y practicar con evidencia          | Sesión normal | Modelo, experimento y nivel de ayuda |
| Día 1   | Reconstruir sin apuntes                     | 10-15 min     | Elementos omitidos o confundidos     |
| Día 7   | Resolver ejercicio diferente                | 20-30 min     | Si la regla se transfiere            |
| Día 21  | Caso de transferencia sin nombre de técnica | 30-45 min     | Hipótesis y nivel A-G                |
| Día 45  | Pregunta o laboratorio sorpresa             | 30-60 min     | Retención, adaptación y autonomía    |

No conviertas el curso completo en flashcards. Solo recupera activamente:

- modelos mentales y flujos;
- preguntas de diagnóstico;
- diferencias entre técnicas próximas;
- primitivas mínimas;
- señales de alta información;
- criterios de confirmación y descarte.

Cada viernes agenda en el calendario D1/D7/D21/D45. Si coinciden más de tres revisiones, prioriza la de un bloqueo recurrente, una transferencia y una sorpresa; pospón el resto un máximo de dos días.

## Checkpoints

### Formato común y rúbrica

Cada checkpoint dura 100-120 minutos:

1. Prueba teórica de recuperación (10 min).
2. Análisis de tráfico (15 min).
3. Interpretación de errores (15 min).
4. Construcción de payload (20 min).
5. Adaptación de payload fallido (20 min).
6. Mini laboratorio ciego (30-40 min).

Puntúa cada dimensión de 0 a 4; total 28:

| Dimensión       | 0                               | 1                        | 2                      | 3                        | 4                                        |
|-----------------|---------------------------------|--------------------------|------------------------|--------------------------|------------------------------------------|
| Reconocimiento  | No localiza entrada             | Enumera al azar          | Ve señal principal     | Prioriza señales         | Reconoce y descarta señuelos             |
| Razonamiento    | Salta a receta                  | Una hipótesis            | Flujo parcial          | Hipótesis rivales        | Predicciones completas                   |
| Experimentación | Sin control                     | Cambia varias cosas      | Baseline básico        | Una variable y control   | Experimento discriminatorio reproducible |
| Construcción    | Copia cadena                    | Componentes incoherentes | Sintaxis parcial       | Payload válido explicado | Mínimo, explicado y controlado           |
| Adaptación      | Prueba bypasses al azar         | Cambia caracteres        | Identifica restricción | Cambia capa causal       | Predice límites de la adaptación         |
| Interpretación  | Confunde error con confirmación | Lee código superficial   | Extrae una señal       | Separa causas            | Integra tráfico, error y estado          |
| Autonomía       | Write-up completo               | Solución parcial         | Pista técnica/payload  | Pista conceptual/docs    | Sin ayuda con registro riguroso          |

### Checkpoint 1 (semana 4) — Fundamentos experimentales

- Teoría: HTTP, URL, sesión, parser, shell/argv y source-sink.
- Tráfico: una petición con cookie, JSON, redirect y respuesta cacheada.
- Error: separar parser JSON, validación y aplicación.
- Construcción: prueba mínima para una entrada que llega a un comando desconocido.
- Adaptación: el separador queda literal.
- Ciego: clasificar dos wrappers locales y documentar el flujo.

### Checkpoint 2 (semana 8) — Adaptación web

- Teoría: SQLi, traversal/LFI y SSRF mediante diferencias, no definiciones.
- Tráfico: callback, redirect y resolución de nombre.
- Error: comilla, ruta inexistente y timeout con hipótesis rivales.
- Construcción: par booleano o ruta relativa desde sintaxis dada.
- Adaptación: filtro actúa sobre una representación distinta.
- Ciego: endpoint desconocido; confirmar solo la primitiva mínima.

### Checkpoint 3 (semana 12) — Web y Linux

- Teoría: upload, sesión/MFA, sudo y SUID.
- Tráfico: matriz identidad-estado-objeto.
- Error: distinguir permiso, parser y ausencia de consumidor.
- Construcción: marcador mínimo con identidad efectiva.
- Adaptación: regla sudo fija o SUID que pierde privilegios.
- Ciego: VM con tres hallazgos, solo uno explotable de forma inocua.

### Checkpoint 4 (semana 16) — Integrador ciego

- Teoría: Windows, AD, redes y transferencia de modelos anteriores.

- Tráfico: PCAP breve con DNS, autenticación y conexión bloqueada.
- Error: servicio Windows, Kerberos o túnel; identificar capa.
- Construcción: prueba mínima según parser/herramienta observada.
- Adaptación: cambia entorno, ruta o identidad, no caracteres al azar.
- Ciego: escenario de 40 minutos con un vector real y dos señuelos.

## **Decisión tras cada checkpoint**

- 24-28: avanza y aumenta transferencia/sorpresa.
- 20-23: avanza, pero repite en D7 la dimensión más baja.
- 16-19: repite dos sesiones prácticas antes de avanzar.
- < 16 o dimensión 0: pausa una semana; vuelve al modelo fundamental y a un laboratorio mínimo.

La nota no reemplaza el nivel A-G. Registra ambos: competencia y dependencia de ayuda.